
**CONCEPTO
ARQUITECTURA EMPRESARIAL
PORTAL TARJETA HABIENTE POMELO
CREDIBANCO
VERSIÓN 1.0**

HISTORIA DE REVISIONES

Fecha	Versión	Descripción	Autor
09/06/2026	1.0	Versión Inicial	Javier Ricardo Agudelo

TABLA DE CONTENIDO

HISTORIA DE REVISIONES	2
TABLA DE CONTENIDO	3
GUÍA DE USO	4
NECESIDAD.....	5
PREMISAS DEL CONCEPTO	7
LINEAMIENTOS	9
RESTRICCIONES	11
ARQUITECTURA PROPUESTA	13
Diagrama de Arquitectura.....	13
Descripción de componentes	14
Descripción del proceso.....	15
ANEXOS.....	18

GUÍA DE USO

El presente documento detalla el concepto del equipo de arquitectura empresarial generado para la necesidad expuesta por el negocio. Se identifica la necesidad, premisas, lineamientos, restricciones y se detalla la arquitectura propuesta.

A su vez, contiene el detalle de los elementos evaluados y el análisis a alto nivel de los posibles componentes involucrados dentro de Credibanco.

Cómo diligenciar este documento:

- No se deben eliminar las anotaciones al inicio de cada sección con información de lo que debe contener cada punto. Estas notas sirven para ayudar a determinar la información a rellenar y para ayudar a las personas que revisan el documento a saber que debe estar cumplimentado en cada apartado.
- No se deben eliminar puntos del índice o capítulos del documento. Si algún punto no aplica se pondrá el comentario "NO APLICA".
- No olvide actualizar la fecha y la versión del documento en el encabezado, y el nombre del archivo en el pie de página.
- Tenga la precaución de revisar todos los encabezados y pies de página del documento para confirmar que la información que figura en los mismos está correctamente actualizada, ya que hay encabezados y pies de página para diferentes secciones del documento, y para páginas pares e impares.

NECESIDAD

El presente concepto se enfoca en definir la arquitectura empresarial requerida para habilitar el Portal Web Tarjetahabiente Prepago, solución orientada a permitir que los tarjetahabientes de tarjetas prepago administren de forma autónoma, segura y trazable los procesos asociados a su registro, autenticación y gestión básica de tarjeta.

Actualmente, dentro del proceso de tarjetas prepago, se requiere disponer de un canal digital que permita al tarjetahabiente realizar el pre-registro, iniciar sesión, restablecer o cambiar su contraseña, activar su tarjeta nominada, gestionar el cambio de PIN y visualizar información sensible de la tarjeta, garantizando que dichos procesos cumplan con los lineamientos de seguridad, auditoría, cumplimiento normativo y experiencia de usuario definidos para Credibanco.

La necesidad de negocio parte de habilitar una experiencia digital controlada para el tarjetahabiente, reduciendo la dependencia de procesos manuales o asistidos, y permitiendo que el usuario final pueda completar los flujos de autoservicio definidos para la plataforma prepago. Para esto, se requiere una arquitectura que integre el portal web, los servicios backend, el proveedor de identidad, la persistencia de información, los mecanismos de auditoría y la integración con Pomelo como procesador y proveedor de capacidades especializadas para tarjetas.

El alcance principal de esta necesidad contempla la implementación de un portal tarjetahabiente que permita:

- Realizar el pre-registro del tarjetahabiente mediante validación de identidad, correo registrado y autenticación mediante OTP.
- Permitir el inicio de sesión del tarjetahabiente utilizando número de documento y contraseña.
- Habilitar el restablecimiento de contraseña en caso de olvido.
- Permitir el cambio de contraseña desde el portal, cumpliendo las políticas de seguridad definidas.
- Orquestar la activación de tarjeta nominada mediante integración con el iframe de Pomelo.
- Orquestar el cambio de PIN mediante iframe de Pomelo.
- Permitir la visualización de información sensible de tarjeta exclusivamente a través del iframe de Pomelo.
- Registrar la trazabilidad funcional y técnica de los eventos ejecutados por el tarjetahabiente.
- Garantizar controles de seguridad sobre autenticación, autorización, bloqueo por intentos fallidos, expiración de sesión, auditoría y protección de datos sensibles.

Como principio fundamental de la solución, todo el manejo de PIN e información sensible de tarjeta será realizado exclusivamente dentro del iframe de Pomelo. Credibanco no capturará, procesará, almacenará, descifrá, renderizará ni registrará PIN, PAN completo, CVV2 o información sensible visible al tarjetahabiente. La responsabilidad de Credibanco se limita a autenticar al usuario, validar su autorización, orquestar la apertura segura del iframe, recibir la confirmación del resultado del proceso y registrar auditoría sin incluir valores sensibles.

La arquitectura propuesta deberá permitir la separación clara de responsabilidades entre el Portal Tarjetahabiente, las APIs backend de Credibanco, el proveedor de identidad, la base de datos transaccional, los componentes de auditoría y la integración con Pomelo. Esta separación busca reducir la exposición de información sensible, facilitar la trazabilidad extremo a extremo, cumplir con los lineamientos de seguridad aplicables y asegurar que los procesos críticos del tarjetahabiente sean ejecutados de forma controlada.

Adicionalmente, la solución debe contemplar que los procesos de activación de tarjeta, cambio de PIN y visualización de datos sensibles dependen de la correcta integración con Pomelo, por lo cual se requiere definir contratos técnicos claros para la creación de sesiones de iframe, manejo de respuestas, callbacks, webhooks, errores, timeouts, expiraciones e idempotencia de las operaciones.

En conclusión, la necesidad consiste en habilitar una capacidad digital segura para el tarjetahabiente prepago, soportada por una arquitectura empresarial que permita operar los procesos de onboarding, autenticación y gestión básica de tarjeta, manteniendo la información sensible fuera del dominio de Credibanco y delegando dichas funciones especializadas al iframe de Pomelo.

PREMISAS DEL CONCEPTO

Esta sección presenta las premisas que rigen la arquitectura propuesta para el Portal Web Tarjetahabiente Prepago.

Para la definición de la arquitectura se consideran las siguientes premisas:

- El Portal Web Tarjetahabiente será el canal digital mediante el cual el tarjetahabiente podrá realizar procesos de autoservicio asociados a su tarjeta prepago, de acuerdo con el alcance definido para la Fase 1 de la solución.
- El alcance funcional inicial contempla los procesos de pre-registro, autenticación, restablecimiento de contraseña, cambio de contraseña, activación de tarjeta nominada, cambio de PIN y visualización de información sensible de tarjeta.
- El Portal Tarjetahabiente será implementado como una aplicación web desacoplada del backend, utilizando una arquitectura basada en componentes frontend, APIs backend, proveedor de identidad, persistencia transaccional e integración con servicios externos.
- La autenticación y gestión de identidad del tarjetahabiente se realizará a través de un proveedor de identidad corporativo basado en Keycloak, utilizando un realm independiente para los usuarios tarjetahabientes.
- El tarjetahabiente deberá contar con un proceso de pre-registro exitoso antes de poder autenticarse y operar las funcionalidades disponibles en el portal.
- El pre-registro del tarjetahabiente deberá validar la identidad del usuario, el correo registrado y la autenticación mediante OTP, garantizando que el acceso inicial al portal se realice de forma controlada.
- Las políticas de contraseña, expiración de sesión, bloqueo por intentos fallidos, duración de token y demás controles de autenticación deberán alinearse con los lineamientos de seguridad definidos para la solución.
- Todo el manejo de PIN e información sensible de tarjeta será realizado exclusivamente dentro del iframe de Pomelo. Credibanco no capturará, procesará, almacenará, descifrá, renderizará ni registrará PIN, PAN completo, CVV2 o información sensible visible al tarjetahabiente.
- La responsabilidad de Credibanco frente a los procesos soportados por el iframe de Pomelo será autenticar al tarjetahabiente, validar su autorización, orquestar la apertura segura del iframe, recibir la confirmación del resultado del proceso y registrar auditoría sin incluir valores sensibles.
- La activación de tarjeta nominada, el cambio de PIN y la visualización de información sensible de tarjeta dependerán de la integración con Pomelo mediante iframe, de acuerdo con los contratos técnicos que sean definidos entre Credibanco y Pomelo.
- El Portal Tarjetahabiente no deberá exponer, transportar ni almacenar información sensible de tarjeta en el frontend, backend, logs, trazas, herramientas de monitoreo, eventos, colas, bases de datos o componentes de auditoría.
- Toda operación ejecutada por el tarjetahabiente deberá contar con trazabilidad funcional y técnica, incluyendo identificación del usuario, operación realizada, fecha y hora, resultado del proceso, componente responsable y correlación extremo a extremo.
- Los eventos asociados a operaciones sensibles deberán registrarse únicamente con metadatos de negocio y técnicos, sin incluir valores sensibles como PIN, PAN completo, CVV2 o información confidencial de la tarjeta.
- La arquitectura deberá contemplar mecanismos de seguridad para proteger la sesión del usuario, controlar la autorización sobre las tarjetas asociadas al tarjetahabiente y evitar el acceso no autorizado a funcionalidades del portal.
- La comunicación entre el Portal Tarjetahabiente, los servicios backend, el proveedor de identidad, los componentes internos y Pomelo deberá realizarse mediante canales seguros.
- La solución deberá ejecutarse sobre la plataforma tecnológica definida por Credibanco para este tipo de componentes, contemplando despliegue en

contenedores, exposición controlada de APIs, monitoreo, trazabilidad y gestión operativa.

- La persistencia de información funcional, estados del proceso, auditoría y trazabilidad se realizará en los repositorios definidos por la arquitectura, evitando almacenar datos sensibles que sean responsabilidad exclusiva de Pomelo.
- Las integraciones con Pomelo deberán contemplar manejo de errores, timeouts, expiración de sesiones, confirmación de resultados, idempotencia y mecanismos de conciliación cuando aplique.
- La solución deberá permitir separar claramente las responsabilidades entre el Portal Tarjetahabiente, las APIs backend de Credibanco, el proveedor de identidad, la base de datos, los componentes de auditoría y la integración con Pomelo.
- Las funcionalidades complementarias como consulta de saldo, historial de transacciones, bloqueo/desbloqueo, consulta de estado de tarjeta, extractos y activación de tarjeta innominada serán consideradas como alcance posterior o Fase 2, salvo definición contraria del negocio.
- Cualquier cambio en el alcance funcional, en la responsabilidad de manejo de datos sensibles o en el modelo de integración con Pomelo deberá ser evaluado por Arquitectura Empresarial, Seguridad de la Información y las áreas responsables de cumplimiento.

LINEAMIENTOS

Esta sección presenta los lineamientos que rigen la arquitectura propuesta para el Portal Web Tarjetahabiente Prepago.

La solución deberá contemplar los siguientes lineamientos arquitectónicos, técnicos, funcionales y de seguridad:

- La arquitectura del Portal Tarjetahabiente deberá estar orientada a una separación clara de responsabilidades entre la capa de presentación, la capa de servicios backend, el proveedor de identidad, la persistencia de información, los componentes de auditoría y las integraciones externas.
- El Portal Tarjetahabiente deberá operar como una aplicación web desacoplada, consumiendo exclusivamente servicios backend definidos para la solución. No se deberán implementar reglas críticas de negocio únicamente en el frontend.
- Todas las funcionalidades expuestas al tarjetahabiente deberán ser consumidas a través de APIs controladas, versionadas y protegidas mediante mecanismos de autenticación, autorización, validación de sesión y trazabilidad.
- El backend del Portal Tarjetahabiente deberá actuar como una capa de orquestación o BFF, centralizando la validación del usuario autenticado, la autorización sobre las tarjetas asociadas, la coordinación con servicios internos y la integración con Pomelo.
- La autenticación de los tarjetahabientes deberá realizarse mediante el proveedor de identidad definido para la solución, utilizando un realm independiente para este tipo de usuarios y aplicando las políticas de contraseña, sesión, expiración de token y bloqueo definidas por Seguridad de la Información.
- El acceso a las funcionalidades del portal deberá estar controlado mediante roles, perfiles, claims o atributos que permitan validar que el tarjetahabiente solo pueda consultar u operar información asociada a su propia identidad y a sus tarjetas autorizadas.
- El proceso de pre-registro deberá garantizar la validación de identidad del tarjetahabiente, la correspondencia con el correo registrado y la verificación mediante OTP, evitando habilitar usuarios sin una validación previa suficiente.
- Los enlaces de pre-registro y restablecimiento de contraseña deberán utilizar identificadores opacos, temporales y de un solo uso. No se deberán exponer datos personales como tipo de documento, número de documento o correo electrónico en la URL.
- Las operaciones de activación de tarjeta nominada, cambio de PIN y visualización de información sensible deberán ser orquestadas desde Credibanco, pero ejecutadas exclusivamente dentro del iframe de Pomelo.
- Todo el manejo de PIN, PAN completo, CVV2, fecha de expiración y demás información sensible visible al tarjetahabiente deberá permanecer exclusivamente dentro del dominio del iframe de Pomelo. Estos datos no deberán ser capturados, transportados, procesados, renderizados, almacenados ni registrados por componentes de Credibanco.
- La integración con el iframe de Pomelo deberá realizarse mediante sesiones temporales, seguras, trazables y con expiración controlada, evitando la reutilización no autorizada de sesiones o enlaces.
- La apertura del iframe de Pomelo deberá estar precedida por validaciones de autenticación, autorización, estado de la tarjeta, relación entre tarjeta y tarjetahabiente, y demás condiciones funcionales definidas para cada proceso.
- Para la visualización de información sensible de tarjeta, se deberá aplicar un mecanismo de autenticación reforzada o step-up antes de habilitar la apertura del iframe correspondiente.
- Las operaciones sensibles no deberán exponerse mediante métodos HTTP que puedan generar ambigüedad, cacheo o ejecución no controlada. La creación de sesiones

de operación o iframe deberá realizarse mediante servicios transaccionales protegidos.

- La comunicación entre el Portal Tarjetahabiente, las APIs backend, el proveedor de identidad, los componentes internos y Pomelo deberá realizarse mediante canales seguros, utilizando cifrado en tránsito y controles de seguridad compatibles con los lineamientos corporativos.
- Todos los servicios backend deberán implementar validación de entrada, manejo controlado de errores, sanitización de datos, control de sesión, control de autorización y protección frente a exposición accidental de información sensible.
- La solución deberá evitar el registro de información sensible en logs de aplicación, logs de infraestructura, trazas distribuidas, herramientas APM, consolas, bases de datos, colas, eventos, reportes o auditoría.
- La auditoría deberá registrar los eventos relevantes del tarjetahabiente incluyendo usuario, operación, fecha y hora, resultado, componente, dirección de origen cuando aplique, identificadores de correlación y estado del proceso, sin incluir valores sensibles.
- Todas las operaciones deberán contar con un identificador de correlación que permita realizar trazabilidad extremo a extremo entre el portal, las APIs internas, los servicios de integración, Pomelo y los eventos de auditoría.
- Los servicios que reciban confirmaciones o eventos desde Pomelo deberán validar autenticidad, integridad, vigencia e idempotencia del mensaje recibido, evitando reprocesamientos, duplicidad de estados o inconsistencias transaccionales.
- Los procesos de activación de tarjeta, cambio de PIN y visualización de datos sensibles deberán contar con manejo explícito de estados, timeouts, errores, cancelaciones, expiración de sesión, reintentos y conciliación cuando aplique.
- La arquitectura deberá considerar mecanismos de resiliencia para las integraciones externas, incluyendo control de timeouts, circuit breaker, reintentos controlados, backoff, colas de fallos o mecanismos equivalentes de recuperación.
- El diseño deberá contemplar que la indisponibilidad del iframe de Pomelo o de sus servicios asociados impacta directamente las funcionalidades de activación, cambio de PIN y visualización de información sensible, por lo cual deberá definirse el comportamiento funcional ante indisponibilidad.
- La persistencia de información deberá limitarse a datos funcionales, estados de proceso, trazabilidad, auditoría y metadatos requeridos para la operación. No se deberán almacenar datos sensibles cuya responsabilidad haya sido delegada a Pomelo.
- La solución deberá contemplar una separación clara entre las funcionalidades incluidas en la Fase 1 y las funcionalidades complementarias o diferenciales consideradas para fases posteriores, evitando ambigüedad en el alcance de implementación.
- La arquitectura deberá ser compatible con despliegue en contenedores y operación sobre la plataforma tecnológica definida por Credibanco, considerando monitoreo, observabilidad, gestión de configuración, escalabilidad y continuidad operativa.
- Las APIs deberán ser diseñadas bajo principios de reutilización, bajo acoplamiento, versionamiento, contratos claros y documentación técnica suficiente para facilitar mantenimiento, evolución y pruebas.
- Los componentes de la solución deberán exponer métricas técnicas y funcionales que permitan monitorear disponibilidad, latencia, errores, intentos fallidos, bloqueos, sesiones de iframe generadas y eventos de negocio relevantes.
- Cualquier modificación al modelo de manejo de datos sensibles, integración con Pomelo, autenticación, autorización o responsabilidades de los componentes deberá ser evaluada por Arquitectura Empresarial, Seguridad de la Información y las áreas responsables de cumplimiento antes de su implementación.

RESTRICCIONES

Esta sección presenta las restricciones que rigen la arquitectura propuesta para el Portal Web Tarjetahabiente Prepago.

Para la definición, diseño e implementación de la solución se identifican las siguientes restricciones:

- La solución se limita al alcance definido para el Portal Tarjetahabiente Prepago. No se incluyen en este concepto las funcionalidades propias del Portal Administrativo, salvo aquellas integraciones o dependencias que sean requeridas para soportar los procesos del tarjetahabiente.
- El alcance funcional de la Fase 1 contempla pre-registro, autenticación, restablecimiento de contraseña, cambio de contraseña, activación de tarjeta nominada, cambio de PIN y visualización de información sensible mediante iframe de Pomelo. Las funcionalidades complementarias deberán ser tratadas como alcance posterior, salvo definición contraria del negocio.
- Credibanco no implementará un iframe propio para captura, cambio o administración de PIN.
- Credibanco no implementará un iframe propio para visualización de PAN completo, CVV2, fecha de expiración o información sensible de tarjeta en el flujo del tarjetahabiente.
- Todo el manejo de PIN e información sensible de tarjeta deberá realizarse exclusivamente dentro del iframe de Pomelo. Esta restricción aplica para PIN, PAN completo, CVV2, fecha de expiración y cualquier otro dato sensible visible al tarjetahabiente.
- Los componentes de Credibanco no deberán capturar, procesar, almacenar, descifrar, renderizar, transportar ni registrar PIN, PAN completo, CVV2 o información sensible de tarjeta gestionada por Pomelo.
- La arquitectura de Credibanco deberá limitarse a autenticar al tarjetahabiente, validar su autorización, orquestar la creación de la sesión del iframe, presentar el iframe en el portal, recibir confirmaciones de resultado y registrar auditoría sin datos sensibles.
- La disponibilidad de los procesos de activación de tarjeta nominada, cambio de PIN y visualización de información sensible dependerá de la disponibilidad del iframe y servicios asociados de Pomelo.
- La integración con Pomelo deberá contar con contratos técnicos formales y validados antes de la construcción definitiva, incluyendo creación de sesión de iframe, parámetros requeridos, expiración, mecanismos de seguridad, callbacks, webhooks, manejo de errores, timeouts, cancelaciones e idempotencia.
- No se deberán exponer datos personales o sensibles en las URLs de pre-registro, restablecimiento de contraseña, activación de tarjeta o apertura de iframe. En su lugar, se deberán utilizar identificadores opacos, temporales, trazables y de un solo uso.
- Los enlaces enviados por correo electrónico deberán tener vigencia limitada, control de uso único cuando aplique y mecanismos de expiración o invalidación ante eventos de riesgo.
- Las operaciones sensibles no deberán exponerse mediante métodos HTTP tipo GET cuando impliquen creación de sesión, cambio de estado, activación, apertura de operación sensible o generación de contexto para iframe. Estas operaciones deberán manejarse mediante servicios transaccionales protegidos.
- El frontend del Portal Tarjetahabiente no deberá contener reglas críticas de negocio como única capa de validación. Toda validación relevante deberá realizarse o confirmarse en backend.
- El Portal Tarjetahabiente no deberá almacenar tokens de sesión, información sensible o datos de operación en mecanismos inseguros del navegador. El manejo de sesión deberá seguir los lineamientos definidos por Seguridad de la Información.

- Los datos sensibles no deberán quedar registrados en logs de aplicación, logs de infraestructura, trazas distribuidas, herramientas APM, consolas de navegador, eventos, colas, reportes, auditoría o bases de datos.
- Los eventos de auditoría deberán registrar únicamente metadatos de operación, tales como usuario, identificador de tarjeta no sensible, operación, resultado, fecha, hora, componente, canal y correlación, sin incluir valores sensibles.
- El acceso a funcionalidades del portal estará restringido a tarjetahabientes previamente registrados, autenticados y autorizados. No se deberán permitir operaciones sobre tarjetas que no estén asociadas al usuario autenticado.
- La apertura del iframe de Pomelo deberá estar condicionada a validaciones previas de autenticación, autorización, estado de la tarjeta, relación tarjeta-tarjetahabiente y reglas funcionales definidas para cada operación.
- Para visualizar información sensible de tarjeta, se deberá aplicar autenticación reforzada o mecanismo equivalente antes de habilitar la sesión del iframe correspondiente.
- Los procesos de OTP deberán contemplar expiración, control de intentos, bloqueo temporal o definitivo según corresponda, auditoría y protección del código generado. El OTP no deberá almacenarse ni registrarse en claro.
- La solución deberá ajustarse a la infraestructura y plataformas tecnológicas definidas por Credibanco, incluyendo despliegue en contenedores, exposición controlada de APIs, observabilidad, monitoreo, seguridad perimetral y lineamientos de operación.
- La persistencia de información estará limitada a datos funcionales, estados de proceso, metadatos, trazabilidad y auditoría. No se deberán almacenar datos cuya responsabilidad haya sido delegada a Pomelo.
- Los servicios expuestos por el backend deberán contemplar control de acceso, validación de entrada, manejo controlado de errores, protección contra abuso, control de intentos y trazabilidad extremo a extremo.
- Los webhooks, callbacks o notificaciones provenientes de Pomelo deberán validar autenticidad, integridad, vigencia, origen e idempotencia antes de actualizar estados internos de Credibanco.
- La solución deberá contemplar mecanismos de manejo de indisponibilidad o degradación funcional cuando Pomelo, el proveedor de identidad, la base de datos o los servicios internos requeridos no estén disponibles.
- Cualquier cambio que implique que Credibanco capture, procese, almacene o visualice información sensible de tarjeta deberá ser evaluado previamente por Arquitectura Empresarial, Seguridad de la Información, Cumplimiento y las áreas responsables de PCI.
- La arquitectura deberá mantener separación clara entre las funcionalidades de Fase 1 y Fase 2, evitando que funcionalidades no priorizadas sean asumidas como parte del alcance inicial sin aprobación formal.
- Los componentes, APIs, bases de datos, colas, logs y mecanismos de monitoreo deberán ser revisados para asegurar que no exista exposición directa o indirecta de información sensible del tarjetahabiente.
- Toda dependencia externa crítica para el flujo del tarjetahabiente deberá contar con definición de responsabilidades, acuerdos de integración, manejo de errores, trazabilidad y criterios de aceptación antes de su paso a producción.

Descripción de componentes

Identificador	Componente	Descripción
PTH-001	Tarjetahabiente	Usuario final de la tarjeta prepago que accede al portal para realizar procesos de registro, autenticación y gestión básica de su tarjeta.
PTH-002	Portal Web Tarjetahabiente	Aplicación web utilizada por el tarjetahabiente. Permite ejecutar los flujos de pre-registro, login, restablecimiento/cambio de contraseña, activación de tarjeta, cambio de PIN y visualización de información sensible mediante iframe de Pomelo.
PTH-003	API Gateway / Capa de exposición	Componente de entrada para las APIs del Portal Tarjetahabiente. Centraliza exposición controlada, seguridad perimetral, enrutamiento, validaciones técnicas, control de tráfico y trazabilidad de solicitudes.
PTH-004	Prepaid Cardholder API / BFF	Capa backend del Portal Tarjetahabiente. Orquesta las operaciones del usuario, valida la sesión, controla autorización sobre tarjetas, coordina servicios internos y gestiona la creación de sesiones de iframe con Pomelo.
PTH-005	Keycloak CARDHOLDER	Proveedor de identidad para tarjetahabientes. Gestiona autenticación, emisión de tokens, políticas de contraseña, expiración de sesión, bloqueo por intentos fallidos y administración del ciclo de vida del usuario.
PTH-006	PreRegistration Service	Servicio responsable de gestionar el proceso de pre-registro del tarjetahabiente, validando la información inicial, estado del proceso, intentos, bloqueos y habilitación del usuario para el acceso al portal.
PTH-007	OTP Service	Servicio encargado de generar, enviar, validar y controlar la vigencia de códigos OTP requeridos en los procesos de pre-registro, recuperación de contraseña o autenticación reforzada cuando aplique.
PTH-008	B2B Mail Service	Servicio encargado de enviar las notificaciones de correo electrónico requeridas por los flujos del portal, incluyendo pre-registro, confirmación de registro, restablecimiento de contraseña, bloqueos y notificaciones de ingreso.
PTH-009	Pomelo Iframe Adapter	Componente encargado de orquestar la creación de sesiones temporales, seguras y trazables para abrir el iframe de Pomelo en operaciones como activación de tarjeta nominada, cambio de PIN y visualización de información sensible.
PTH-010	Pomelo API Client	Cliente técnico utilizado por los servicios backend de Credibanco para consumir las APIs de Pomelo requeridas en la creación de sesiones de iframe, validación de estados o consulta de información no sensible permitida por contrato.
PTH-011	Iframe Pomelo	Componente externo provisto por Pomelo donde se ejecutan las operaciones de activación de tarjeta, captura/cambio de PIN y visualización de información sensible. En este componente se manejan PIN, PAN completo, CVV2 y demás datos sensibles visibles al tarjetahabiente.

PTH-012	Prepaid Webhook Integrator	Servicio receptor de eventos, callbacks o confirmaciones enviados por Pomelo. Valida autenticidad, integridad, vigencia e idempotencia de los mensajes antes de actualizar estados internos.
PTH-013	Base de datos transaccional	Repositorio de información funcional del portal, estados de proceso, usuarios asociados, relación tarjetahabiente-tarjeta, metadatos operativos y trazabilidad. No deberá almacenar PIN, PAN completo, CVV2 o información sensible gestionada por Pomelo.
PTH-014	audit_log / pci_event_log	Repositorios o estructuras de auditoría para registrar eventos funcionales y de seguridad relacionados con el uso del portal. Deben almacenar únicamente metadatos de operación, sin valores sensibles.
PTH-015	Observabilidad y monitoreo	Capacidades de monitoreo, métricas, logs técnicos y trazabilidad distribuida para identificar disponibilidad, errores, latencia, intentos fallidos, bloqueos, eventos de integración y comportamiento de la solución.

Tabla 1. – Listado Responsabilidades de Componentes

Descripción del proceso

1. Pre-registro del tarjetahabiente

El proceso inicia cuando el tarjetahabiente recibe un enlace de pre-registro asociado a la creación de su tarjeta prepago. El enlace deberá contener un identificador opaco, temporal y controlado, evitando exponer datos personales en la URL.

El tarjetahabiente accede al Portal Web Tarjetahabiente y diligencia la información requerida para validar su identidad. El Portal consume los servicios backend del Prepaid Cardholder API, el cual coordina el proceso con el PreRegistration Service y el OTP Service.

El OTP es enviado al correo registrado del tarjetahabiente mediante el B2B Mail Service. Una vez validado el OTP dentro de su vigencia y respetando los controles de intentos definidos, el sistema habilita la creación o activación del usuario en Keycloak CARDHOLDER. Posteriormente, el tarjetahabiente define su contraseña cumpliendo las políticas establecidas por Seguridad de la Información.

Durante el proceso se registran los estados funcionales, intentos, bloqueos, expiraciones y resultado final, garantizando trazabilidad sin registrar contraseñas ni códigos OTP en claro.

2. Autenticación del tarjetahabiente

El tarjetahabiente ingresa al Portal Web utilizando su número de documento y contraseña. El Portal redirige o consume el flujo de autenticación definido con Keycloak CARDHOLDER. Una vez autenticado, Keycloak emite el token correspondiente con los claims, roles o atributos requeridos para operar en el portal.

El backend valida el token recibido, identifica al tarjetahabiente y verifica que las operaciones solicitadas correspondan a tarjetas asociadas a su identidad. La sesión deberá tener vigencia limitada y estar sujeta a las políticas de expiración, bloqueo y reautenticación definidas.

Cada ingreso exitoso, intento fallido o bloqueo deberá generar eventos de auditoría y notificación cuando aplique.

3. Restablecimiento y cambio de contraseña

Para el restablecimiento de contraseña, el tarjetahabiente solicita la recuperación desde el Portal Web. El backend valida la información del usuario, genera un enlace temporal y coordina el envío del correo correspondiente. El enlace no deberá exponer datos personales en claro.

Para el cambio de contraseña desde sesión autenticada, el tarjetahabiente deberá ingresar su contraseña actual, definir una nueva contraseña y confirmarla. La validación y actualización de credenciales se realizará a través de Keycloak CARDHOLDER, aplicando las políticas de seguridad definidas.

Los eventos de éxito, error, bloqueo o vencimiento deberán quedar registrados en auditoría sin almacenar contraseñas ni datos sensibles.

4. Activación de tarjeta nominada

Una vez autenticado, el tarjetahabiente selecciona la opción de activación de tarjeta nominada. El Portal solicita al Prepaid Cardholder API la creación de una sesión de operación para activación.

El backend valida que el usuario esté autenticado, que la tarjeta pertenezca al tarjetahabiente, que la tarjeta se encuentre en estado válido para activación y que se cumplan las reglas funcionales definidas. Posteriormente, el Pomelo Iframe Adapter solicita a Pomelo la creación de una sesión temporal de iframe para la operación.

El Portal Web presenta el iframe de Pomelo al tarjetahabiente. La captura de la información requerida para la activación y la asignación de PIN se realiza exclusivamente dentro del iframe de Pomelo. Credibanco no recibe ni procesa PIN ni información sensible de tarjeta.

Una vez finalizado el proceso, Pomelo informa el resultado mediante callback, webhook o mecanismo definido contractualmente. El Prepaid Webhook Integrator recibe el evento, valida su autenticidad e idempotencia, actualiza el estado funcional correspondiente y registra la auditoría sin datos sensibles.

5. Cambio de PIN

El tarjetahabiente autenticado selecciona la opción de cambio de PIN. El backend valida la identidad del usuario, la relación con la tarjeta y el estado permitido para ejecutar la operación.

Luego, mediante el Pomelo Iframe Adapter, se crea una sesión temporal para abrir el iframe de Pomelo. El cambio de PIN se realiza exclusivamente dentro del iframe de Pomelo, por lo cual Credibanco no captura, transporta, procesa, almacena ni registra el PIN actual o nuevo. Pomelo procesa el resultado del cambio de PIN y envía la confirmación a Credibanco mediante el mecanismo de integración definido. Credibanco actualiza los estados funcionales permitidos y registra el evento de auditoría sin información sensible.

6. Visualización de información sensible de tarjeta

Cuando el tarjetahabiente requiera visualizar información sensible de su tarjeta, el Portal deberá solicitar al backend la creación de una sesión de operación. Antes de permitir la apertura del iframe, el backend deberá validar autenticación, autorización, relación tarjeta-tarjetahabiente, estado de tarjeta y autenticación reforzada o step-up cuando aplique.

Una vez cumplidas las validaciones, el Pomelo Iframe Adapter solicita a Pomelo la creación de una sesión temporal de iframe para visualización de información sensible.

El Portal presenta el iframe de Pomelo al tarjetahabiente. La visualización de PAN completo, CVV2, fecha de expiración y demás datos sensibles ocurre exclusivamente dentro del iframe de Pomelo. El Portal Web y los servicios backend de Credibanco no reciben, renderizan ni almacenan dichos datos.

Credibanco registra únicamente el evento de visualización con metadatos de auditoría, tales como usuario, operación, tarjeta referenciada mediante identificador no sensible, fecha, hora, resultado, canal y correlación.

7. Recepción de eventos desde Pomelo

Los eventos asociados a activación, cambio de PIN, visualización de información sensible u otros eventos administrativos enviados por Pomelo serán recibidos por el Prepaid Webhook Integrator.

Este componente deberá validar la firma o mecanismo de autenticidad definido, verificar la vigencia del evento, controlar duplicidad mediante idempotencia, asociar el evento con la operación original y actualizar el estado correspondiente en la base de datos.

En caso de errores, mensajes duplicados, eventos vencidos o inconsistencias, el servicio deberá registrar el evento técnico, evitar reprocesamientos indebidos y activar los mecanismos de conciliación o manejo de fallos definidos.

8. Auditoría y trazabilidad

Todas las operaciones relevantes del Portal Tarjetahabiente deberán generar trazabilidad funcional y técnica. La auditoría deberá incluir usuario, operación, resultado, fecha y hora, componente responsable, identificador de correlación, estado del proceso y canal.

No se deberán registrar valores sensibles como PIN, PAN completo, CVV2, fecha de expiración completa, contraseñas, OTP en claro o cualquier información que incremente el alcance de exposición de Credibanco.

La solución deberá permitir trazabilidad extremo a extremo entre el Portal Web, las APIs backend, Keycloak, servicios internos, Pomelo, webhooks y repositorios de auditoría.

ANEXOS

<Se incluye documentos de referencia que hacen parte del diseño de Arquitectura >

<Autores: Arquitecto>

NOMBRE	OBSERVACIONES
	<Link de referencia del anexo>

Tabla 2.